

PROYECTO: IMPLEMENTACIÓN DE RED SEGMENTADA PARA PEQUEÑA OFICINA

Fecha de Actualización: 31 de Julio de 2026

Elaborado por: Eleonor Arias H.

Versión: 1.0

OBJETIVO DEL PROYECTO

El presente proyecto tiene como objetivo diseñar e implementar una infraestructura de red local (LAN/WLAN) para una oficina corporativa de tamaño pequeño/mediano.

El propósito principal fue demostrar la capacidad de configurar equipos de red (Router, Switch y Access Points) aplicando buenas prácticas de ciberseguridad mediante la segmentación de red (VLANs) y la implementación de un firewall perimetral (ACLs).

Existe la necesidad crítica de proteger la información corporativa frente a amenazas internas y externas, por ello, se ha diseñado una red basada en el principio de "Confidencialidad y Mínimo Privilegio".

Se utiliza la segmentación lógica (VLANs) y un firewall perimetral (ACLs), garantizando que los datos de los departamentos de Administración, Ventas y Recursos Humanos (RRHH) estén estrictamente aislados entre sí, y que el acceso a los servidores corporativos esté restringido únicamente a los servicios autorizados (puertos web).

Este diseño mitiga el riesgo de filtración de datos, limita el movimiento lateral de posibles atacantes y demuestra el compromiso de la organización con el cumplimiento de normativas como el GDPR (Reglamento General de Protección de Datos) y la ISO 27001.

En el panorama actual de ciberseguridad, las amenazas no solo provienen del exterior, sino que, un gran porcentaje de las brechas de seguridad se originan por accesos no autorizados internos (empleados que acceden a información que no les corresponde) o por la propagación de malware (ransomware) dentro de una red plana.

Riesgos detectados en una red sin segmentar:

- **Exposición de Datos Sensibles:** Un empleado de Ventas podría tener acceso accidental o intencionado a los archivos de nómina de RRHH.
- **Incumplimiento Legal:** La falta de controles de acceso específicos vulnera el artículo 32 del GDPR, que exige medidas técnicas para garantizar la seguridad de los datos.
- **Ataque de Ransomware:** Si un equipo del departamento comercial se infecta, el malware se moverá libremente por toda la red, encriptando el servidor de administración y los backups.

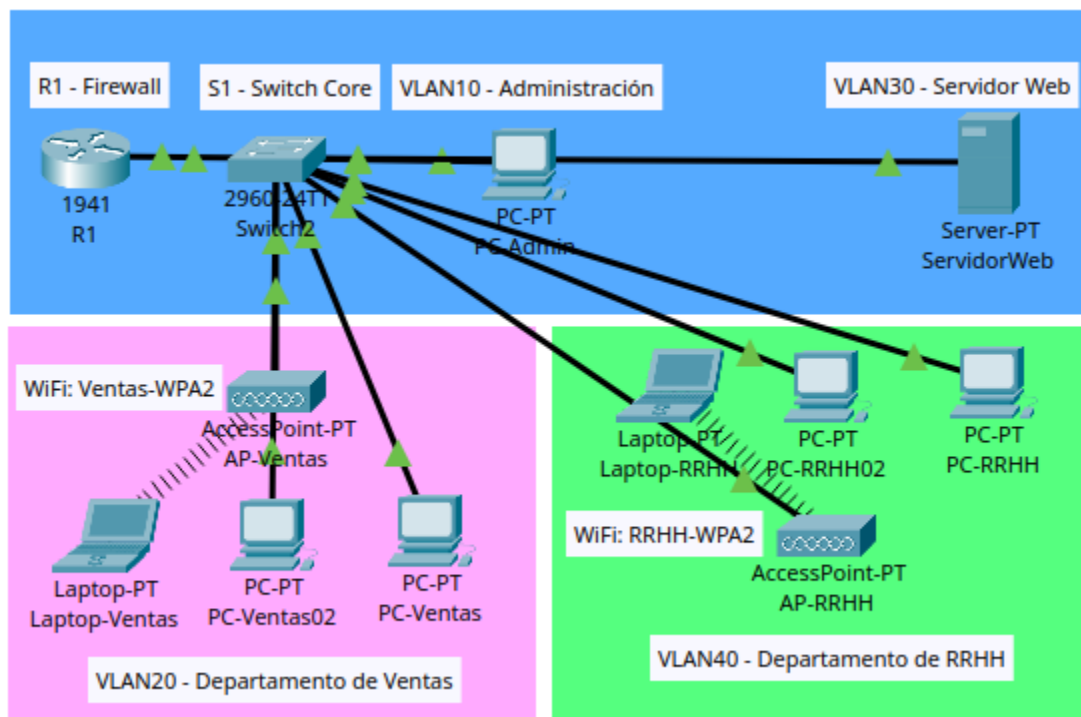
ALCANCE Y TOPOLOGÍA DE RED

Se desplegaron los siguientes componentes lógicos y físicos:

- 1 Router Cisco 1941: Actúa como puerta de enlace (Gateway), enrutador entre VLANs y Firewall.
- 1 Switch Cisco 2960-24TT: Dispositivo de capa 2 encargado de la segmentación física y lógica.
- 2 Access Points: Para proporcionar conectividad inalámbrica a los equipos móviles del departamento de Ventas y RRHH.
- Servidor Web: Para alojar los servicios internos de la empresa.
- Estaciones de trabajo: PCs cableadas y Laptops distribuidas por departamentos.

Tabla de Segmentación (VLANs)

VLAN ID	Nombre	Red IP	Gateway	Uso
10	Administración	192.168.10.0/24	192.168.10.1	Equipo crítico y dirección general
20	Ventas	192.168.20.0/24	192.168.20.1	Equipos cableados e inalámbricos del equipo comercial
30	Servidores	192.168.30.0/24	192.168.30.1	Servidor Web corporativo
40	Recursos Humanos	192.168.40.0/24	192.168.40.1	Equipos cableados e inalámbricos de RRHH



JUSTIFICACIÓN TÉCNICA Y DE SEGURIDAD

A) ¿Por qué integrar VLANs?

La implementación de VLANs responde a una necesidad de arquitectura de seguridad Zero Trust.

- **Aislamiento de Tráfico (Broadcast):** Sin VLANs todas las PCs estarían en un único dominio de broadcast, esto genera tráfico innecesario que consume ancho de banda y permite que un dispositivo "vea" a todos los demás, con VLANs, el tráfico de broadcast queda encapsulado dentro de su propio departamento.
- **Contención de Amenazas:** Si un equipo de Ventas se infecta con malware, el tráfico malicioso queda confinado a la VLAN 20, esto provoca que el atacante no puede moverse lateralmente (por ejemplo, de Ventas a RRHH o al Servidor) a menos que el firewall se lo permita.
- **Principio de Mínimo Privilegio:** A nivel de red, esto significa que un usuario solo tiene acceso a los recursos necesarios para cumplir su función, un trabajador del departamento de ventas no necesita ver los archivos de nómina de RRHH, y RRHH no necesita acceder a los sistemas de gestión de clientes de Ventas sin autorización expresa.

B) ¿Por qué configurar un Firewall basado en ACLs?

El router, al ser el punto de entrada entre las VLANs, funciona como un Firewall de Capa 3 y 4.

- **Control de Acceso:** Las ACLs (Access Control Lists) actúan como un filtro. Permiten o deniegan el tráfico basándose en la dirección IP origen, IP destino, protocolo (TCP/UDP) y puerto.
- **Protección del Servidor Web:** Implementamos una regla crítica: Todos pueden ver el servidor (puerto 80/HTTP), pero nadie puede administrarlo (puerto 22/SSH o ping). Esto reduce la superficie de ataque del servidor, cumpliendo con normativas de ciberseguridad como el OWASP Top 10 en cuanto a configuración segura.

CONTROL DE ACCESOS (FIREWALL)

El punto de conexión entre estas redes es un Firewall (integrado en el router corporativo) que aplica políticas de acceso restrictivas.

Políticas de Seguridad Aplicadas:

Origen	Destino	Acción	Justificación
Ventas	Administración	Denegado	Evita que el personal comercial acceda a información financiera y estratégica.
RRHH	Ventas	Denegado	Protege los datos de nómina del acceso del equipo comercial y viceversa.
Cualquier Red	Servidor Web	Permitido (Solo HTTP)	Permite la operativa de la página web corporativa, pero protege el servidor de ataques de denegación de servicio (DoS) o intentos de acceso remoto (SSH), ya que estos protocolos están bloqueados

Nota: Se configuro de esta manera ya que Packet Tracer no soporta HTTPS de forma nativa en el servidor web, el servidor web de Packet Tracer solo permite HTTP (puerto 80).

IMPLICACIONES LEGALES Y DE CUMPLIMIENTO (EL VALOR PARA LA EMPRESA)

La configuración técnica descrita tiene un impacto directo en la postura legal de la empresa:

A) Cumplimiento del GDPR (Art. 32 - Seguridad del Tratamiento): El GDPR exige que el responsable del tratamiento aplique medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo.

- Demostración Práctica: Este proyecto demuestra que la empresa ha implementado medidas de segregación de red y control de accesos, protegiendo los datos personales de los empleados (RRHH) y los datos de los clientes (Ventas) frente a accesos no autorizados.

B) Principio de "Privacidad por Diseño" (Privacy by Design): La norma exige que la seguridad no sea un "añadido", sino que esté integrada en la arquitectura desde el inicio.

- Demostración Práctica: Al configurar VLANs y ACLs, la seguridad está integrada en el "ADN" de la red. No es un parche, es una funcionalidad base del sistema.

Cumplimiento de la ISO 27001:2022

La implementación responde a múltiples controles de la norma internacional de gestión de seguridad de la información:

- Anexo A.8.20 (Seguridad de redes): Se protegen los datos en tránsito y se defiende la red de amenazas internas y externas mediante firewalls y listas de control de acceso.
- Anexo A.8.22 (Segregación de redes): Se separan los servicios, usuarios y sistemas según el riesgo, aislando las redes de producción, servidores, estaciones de trabajo y WiFi.
- Anexo A.9 (Control de acceso): Se gestiona el acceso lógico a la red y los servicios de red, restringiendo el acceso únicamente a los usuarios y departamentos autorizados

C) Reducción de la Responsabilidad Civil: En caso de un ciberataque (ej. Ransomware en el departamento de Ventas), la segmentación evita que el malware se propague al servidor de Administración o RRHH.

- Implicación Legal: Si un ataque ocurre pero se limita a un solo departamento, el daño (y por tanto, la posible indemnización y la penalización por parte de la Agencia de Protección de Datos) se reduce drásticamente, la empresa puede demostrar que actuó con la debida diligencia.

CONCLUSIÓN Y RECOMENDACIONES

La implementación de esta arquitectura de red demuestra que la organización está alineada con las mejores prácticas internacionales de ciberseguridad y cumple con los estándares legales exigibles.

Recomendaciones a la Dirección:

- **Política de Contraseñas:** Se recomienda complementar esta seguridad de red con una política de autenticación robusta (WPA2-Enterprise) para las redes WiFi, cambiando las contraseñas periódicamente.
- **Plan de Respuesta a Incidentes:** La tecnología debe ir acompañada de un procedimiento legal/operativo que defina cómo actuar ante una violación de seguridad (quiénes, cómo y en qué plazo se notifica a los afectados y a la Agencia de Protección de Datos).
- **Auditoría Periódica:** Revisar las reglas del firewall (ACLs) de forma trimestral para asegurar que ningún usuario o departamento nuevo adquiera permisos innecesarios.

REFERENCIAS:

- Reglamento General de Protección de Datos (GDPR). Diario Oficial de la Unión Europea.
- Directiva NIS2 (UE) 2022/2555. Directiva (UE) 2022/2555 del Parlamento Europeo y del Consejo, de 14 de diciembre de 2022, relativa a las medidas destinadas a garantizar un elevado nivel común de ciberseguridad en toda la Unión, por la que se modifica el Reglamento (UE) n° 910/2014 y la Directiva (UE) 2018/1972, y por la que se deroga la Directiva (UE) 2016/1148. Diario Oficial de la Unión Europea.
- Reglamento de Ejecución (UE) 2024/2690 de la Comisión, de 17 de octubre de 2024, por el que se establecen las medidas técnicas y metodológicas para la gestión de riesgos de ciberseguridad a que se refiere el artículo 21, apartado 2, de la Directiva (UE) 2022/2555 del Parlamento Europeo y del Consejo en lo que respecta a determinadas entidades de los sectores de las infraestructuras digitales, los proveedores digitales y la gestión de servicios de TIC. Diario Oficial de la Unión Europea.
- ENISA (2025). NIS2 Technical Implementation Guidance. Agencia de la Unión Europea para la Ciberseguridad, junio de 2025. Versión 1.0. <https://www.enisa.europa.eu/publications/nis2-technical-implementation-guidance>
- ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements. International Organization for Standardization/International Electrotechnical Commission, 2022.
- ISO/IEC 27002:2022. Information security, cybersecurity and privacy protection — Information security controls. International Organization for Standardization/International Electrotechnical Commission, 2022.